Design compliance you can evidence



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



Materials holds regulated formulation data

Two jurisdictions disagree about where it may live

Legal hands you eleven pages of obligation

What is the first artifact you produce, and who must agree?

Translate an obligation into a control somebody can evidence

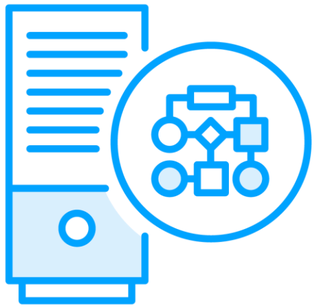
The repeatable move from legal text to evidence



Obligation: what the law requires, written in outcomes



Control intent: what must be true in your estate for that outcome



Technical control: the mechanism that makes it true



Evidence: the artifact an auditor accepts as proof

Address data obligations with Microsoft Purview

Obligations that follow the data, not the resource

Classification finds and labels the regulated data

Protection enforces handling wherever the data travels

The audit record proves the obligation was met

AI governance templates now sit alongside the rest

Enforce the enforceable subset with Azure Policy

A policy engine enforces a subset of any framework

Effect selection is an architectural decision: audit, deny, or deploy

Management group placement decides how far the policy reaches

An honest design says which controls are enforced and which are evidenced by process

Validate alignment in Microsoft Defender for Cloud

The dashboard is a validation instrument, not a verdict



Standard selection follows what law or contract requires



The Microsoft cloud security benchmark is the baseline underneath



The score reports the assessable subset, never the whole obligation

Microsoft Learn, regulatory compliance standards

“Defender for Cloud continually assesses the environment-in-scope against any compliance controls that can be automatically assessed.”

Citation: Microsoft, “Regulatory compliance standards in Microsoft Defender for Cloud”, learn.microsoft.com/azure/defender-for-cloud/concept-regulatory-compliance-standards

Demo: Walk one obligation to its evidence

Walk a regulatory obligation from legal text to an enforced control to the evidence an auditor would accept, then read regulatory compliance in Microsoft Defender for Cloud

Relevant SC-100 practice question

Evidence the access, not the score

Question

A regulator wants proof formulation data was accessed only by authorized staff for twelve months. Defender for Cloud reads 94 percent.

A. Present the compliance score as the evidence

B. Remediate to 100 percent before the audit

C. Verify twelve-month audit retention and produce records

D. Assign an additional regulatory standard

Evidence the access, not the score

Answer: C

A regulator wants proof formulation data was accessed only by authorized staff for twelve months. Defender for Cloud reads 94 percent.

A. Present the compliance score as the evidence

B. Remediate to 100 percent before the audit

C. Verify twelve-month audit retention and produce records

D. Assign an additional regulatory standard

Checking out with Globomantics



Translate obligations into controls with evidence attached

Send data obligations to Purview and resource obligations to Policy

Say which controls are enforced and which are evidenced by process

Validate with the dashboard, and evidence with the artifact

What you can do now

Ready for scattered signals

Give an agent an identity you’re able to govern

Design privileged access

Turn a regulatory obligation into a control